Análise de arquivo anexo: benigno ou malware? Share

exec.pyc

PYC

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Reconsiderando se a análise deve prosseguir

Vou começar lendo as instruções de leitura de arquivos e depois inspecionar o arquivo de forma estática, sem executá-lo.

Ran 3 commands, read a file

Analisei o arquivo de forma estática, lendo o bytecode e as constantes sem executar nada. **Ele é malware**, um backdoor com shell reverso.

1. Identificação

- É um bytecode compilado do CPython 3.13, com 3.990 bytes, gerado a partir de um `.py` de 1.654 bytes.
- SHA-256: `25ed1fe44421faf1fecadc73aa8ed6fec4159f13fadd96fcce8877302a560e24`
- MD5: `76111ab9f56acad0f9b2e4073b1f4706`
- O nome do fonte original embutido é um hash hexadecimal de 64 caracteres, sem relação com "exec". Isso sugere que o arquivo foi renomeado ou salvo por algum processo automatizado.

2. Estrutura e imports

- Importa `socket`, `subprocess`, `json`, `os`, `base64` e `sys`. Essa combinação de rede, execução de processos e manipulação de arquivos é típica de ferramentas de acesso remoto.
- Define uma classe chamada literalmente `Backdoor`, instanciada como `my_backdoor`.
- Não há proteção `if __name__ == "__main__"`, então ele conecta e roda assim que é executado ou importado.

3. Comunicação

- Abre um socket TCP e conecta de dentro para fora (conexão reversa) a `192.168.43.38:4444`, valores fixos no código.

- A porta 4444 é a padrão do Metasploit e muito usada em reverse shells.
- O IP é privado, numa faixa que costuma ser a de hotspot de celular Android. Ele só alcança alguém na mesma rede local.
- As mensagens trafegam em JSON, em texto claro, sem criptografia.

4. Capacidades

Depois de conectar, o script entra em um loop e obedece ao operador remoto:

- `cd`: muda o diretório de trabalho.
- `download`: lê qualquer arquivo, codifica em Base64 e envia, o que permite exfiltrar dados.
- `upload`: recebe conteúdo em Base64 e grava no disco, o que permite plantar outros arquivos ou malwares.
- `exit`: encerra a conexão.
- **Qualquer outro comando:** é executado no sistema com `subprocess.check_output(..., shell=True)` e a saída volta ao operador. Isso dá execução remota arbitrária de comandos.

5. O que o arquivo não tem

Pelos imports e nomes, não há ofuscação, persistência, criptografia, reconexão automática nem roubo de credenciais. É um código simples. Como não tem persistência, alguém ou algo precisou iniciá-lo.

Veredito: malware (backdoor / reverse shell). Quem executar esse arquivo entrega a quem estiver escutando em `192.168.43.38:4444` o controle remoto da máquina, com os privilégios do usuário. A simplicidade e o IP privado sugerem um artefato de laboratório ou estudo, bem parecido com backdoors didáticos de cursos de hacking ético. Mesmo assim, o comportamento é o de um backdoor, qualquer que seja a intenção de quem o escreveu, e ele não é benigno.

Se ele apareceu num computador seu e você não o criou:

- Não execute o arquivo, e isole a máquina da rede se ele já tiver rodado.
- Procure quem o iniciou, verificando tarefas agendadas, itens de inicialização e o processo pai.
- Verifique conexões para `192.168.43.38:4444`.
- Troque senhas, caso o arquivo tenha rodado.

Limitações:

- Não consegui consultar bases como o VirusTotal, pois não há rede no ambiente. Você pode pesquisar o SHA-256 lá.
- O bytecode é do Python 3.13 e meu ambiente tem 3.12. Por isso baseei a conclusão nos nomes e nas constantes, que bastam neste caso, e não em um desassembly completo.

Qual é a categoria principal deste malware?

Escolhendo a resposta mais concisa e justificada ▸

A categoria principal é **backdoor**, mais especificamente um **reverse shell** (shell reverso). Também dá para chamá-lo de RAT (*Remote Access Trojan*) rudimentar, mas ele é muito mais básico que um RAT completo.

O que o define como backdoor é que o próprio script conecta a um servidor do operador e fica aceitando comandos. Isso dá execução remota de comandos, download e upload de arquivos, tudo por um canal que o atacante controla. Ele não se encaixa em outras categorias porque não criptografa arquivos (ransomware), não rouba credenciais ou dados automaticamente (stealer), não se replica (worm ou vírus) e não minera nem mostra anúncios. Também não tem funções típicas de RAT mais completo, como keylogger, captura de tela ou persistência.

Se você precisar classificar em um relatório pelo MITRE ATT&CK, as técnicas que se aplicam são:

- **T1059:** interpretador de comandos e scripts, com Python e `shell=True`.
- **T1095 e T1571:** protocolo TCP próprio, em porta não padrão (4444).
- **T1041:** exfiltração pelo canal de comando e controle (o `download`).
- **T1105:** transferência de ferramentas ou arquivos para a vítima (o `upload`).
- **T1132.001:** codificação dos dados em Base64.

Antivírus costumam rotular esse tipo de arquivo como “Trojan” ou “Backdoor” genérico. Pelo comportamento, “backdoor / reverse shell” é a descrição mais precisa.